

Tinker Tailor LLM Spy

Reconstructing 'Deleted' Chats & Hijacking Sessions from Chromium LevelDB Caches

Target Venue: Black Hat Europe Briefings

Authors: Dr. Sapna V M, Prajwal Chowdary, Prasad H B

Institution: Dept of Computer Science & Engineering, PES University, Bangalore, India

Official Repository: <https://github.com/prajwalchowdary2/tinker-tailor-llm-spy-bheu>

I. Introduction & Ephemeral AI Fallacy

- **Cloud Deletion vs Local Persistence:** When users click 'Delete Chat' in ChatGPT, Claude, Gemini, or Perplexity, cloud backends mark records for deletion, but local endpoints retain serialized traces.
- **LSM-Tree Storage Engine Mechanics:** Chromium browsers (Chrome, Edge) backed by LevelDB write telemetry sequentially to Write-Ahead Logs (.log) and uncompactd Sorted String Tables (.sst/.ldb).
- **Forensic Window:** Until background LSM compaction occurs (which may take hours or days), 'deleted' prompts and credentials remain fully recoverable on local disk.

II. Low-Level V8 Deserialization Architecture

- **Varint Decoding:** Protocol Buffer style variable-length integers where bit 7 indicates continuation.
- **V8 String Tags:** OneByteString (0x22 ASCII) and TwoByteString (0x63 UTF-16LE byte-length tagged parsing).
- **Smi-Shifted Array Keys:** Small Integer (Smi) array indices encoded via left-shift (encoded = actual << 1). Odd actual indices represent User prompts; even actual indices represent Assistant responses.
- **Nesting Depth Tracking:** Dynamic tracking of object/array depth (0x6f/0x61) to prevent premature object termination on inner tags (0x7b).

III. Live Carving & Shadow AI DLP Engine

- **File Lock Bypass:** Read-only binary stream extraction prevents database lock collisions on active user sessions.
- **Multi-Profile Traversal:** Automatically walking Default and secondary profile paths (Profile 1, Profile 2, etc.).
- **Real-Time DLP Engine:** On-the-fly regex pattern scanning for leaked AWS keys, OpenAI API tokens, Slack tokens, and PII.
- **Cryptographic Chain of Custody:** Client-side Web Cryptography API HMAC-SHA256 evidence verification.

IV. 41ms Infostealer Threat Vector PoC

- **Headless Execution PoC (`verity_stealer.py`):** Headless Python script demonstrating sub-50ms harvesting of local LLM telemetry.
- **Bypassing EDR Alerts:** Demonstrates how rapid memory/file read execution occurs before traditional endpoint heuristic alerts trigger.
- **Multi-Application Scope:** Extracts from Chromium LevelDB, Claude TipTap draft keystrokes, Cursor IDE agent transcripts, and VS Code Copilot SQLite databases.

V. Conclusion & Defensive Mitigations

- **Enforce Encryption:** Apply OS-level cryptographic protections (DPAPI / FileVault / BitLocker) to browser IndexedDB LevelDB paths.
- **Browser Eviction Policies:** Configure MDM/GPO clean-up policies for local LevelDB databases on exit.
- **EDR Telemetry Monitoring:** Monitor unprivileged processes accessing Chromium profile paths.
- **Open-Source Tool Release:** The complete Tinker Tailor LLM Spy framework is available on GitHub: <https://github.com/prajwalchowdary2/tinker-tailor-llm-spy-bheu>